Global Enterprise Information Security Policy

Version 4.2 | Classification: Internal | Annual Review Cycle

Executive Overview

This corporate security policy establishes mandatory controls, operational boundaries, and governance standards for safeguarding enterprise information assets, customer privacy, and distributed infrastructure. All full-time employees, contractors, and third-party vendors are required to adhere to these mandates without exception.

Scope and Applicability

The controls documented herein apply across all cloud tenants, physical branch offices, remote developer workstations, and production Kubernetes clusters. Compliance audits are performed biannually in accordance with ISO/IEC 27001 and SOC 2 Type II assurance criteria.

Standard	Governance Framework	Status	Audit Cycle
ISO/IEC 27001:2022	Information Security Management	Certified	Annual Recertification
AICPA SOC 2 Type II	Trust Services Criteria	Compliant	Continuous Monitoring
NIST CSF 2.0	Core Security Profiles	Aligned	Quarterly Self-Assessment
GDPR / CCPA	Data Privacy & Data Residency	Enforced	Ongoing DPO Oversight

Section 2: Credential & Password Management Standards

Password complexity and authentication safety are foundational pillars of our Zero-Trust architecture. To mitigate credential spraying, rainbow table attacks, and unauthorized token reuse, all accounts must satisfy the following:

1. Multi-Factor Authentication (MFA)

Hardware-backed FIDO2/WebAuthn security keys or enterprise Authenticator apps with number-matching prompts are strictly mandatory for accessing single sign-on (SSO) portals. SMS and voice call verification are deprecated and prohibited due to SIM-swapping vulnerabilities.

2. Password Hygiene & Passphrase Guidelines

Master passphrases must comprise a minimum of 16 characters including alphanumeric and approved symbol sets. Employees must utilize the corporate password manager to generate distinct, pseudo-random credentials for every external service. Under no circumstances will IT staff or administrators request your plaintext password via email, ticket, or phone.

3. Session Inactivity and Token Expiration

Interactive web sessions expire automatically after 8 hours of inactivity. Mobile device management (MDM) profiles enforce workstation screen locking after 5 minutes of idle time with biometric re-authentication required.

Section 3: Incident Reporting & Responsibilities

Prompt incident notification enables the Security Operations Center (SOC) to isolate compromised endpoints, revoke active tokens, and prevent lateral movement across enterprise subnets.

Reporting Procedures

If you suspect that your endpoint has encountered suspicious behavior, unsolicited prompts, or potential data loss:

- Immediately use the 'Report Phish' button in your corporate mail client.
- Contact the 24/7 SOC Hotline via internal chat `#security-ops` or phone extension `4433`.
- Do not power off the machine; disconnect Wi-Fi or Ethernet cable to preserve memory artifacts for forensics.

Sanctions for Non-Compliance

Intentional circumvention of security controls, disabling endpoint detection agents, or sharing enterprise credentials subjects personnel to disciplinary review up to and including termination of employment and legal escalation.

Policy Sign-off & Revision Record

Approved by: Chief Information Security Officer (CISO) | Effective Date: January 15, 2026